request is processed as if it was genuine unless extra checks are made to prevent these requests.

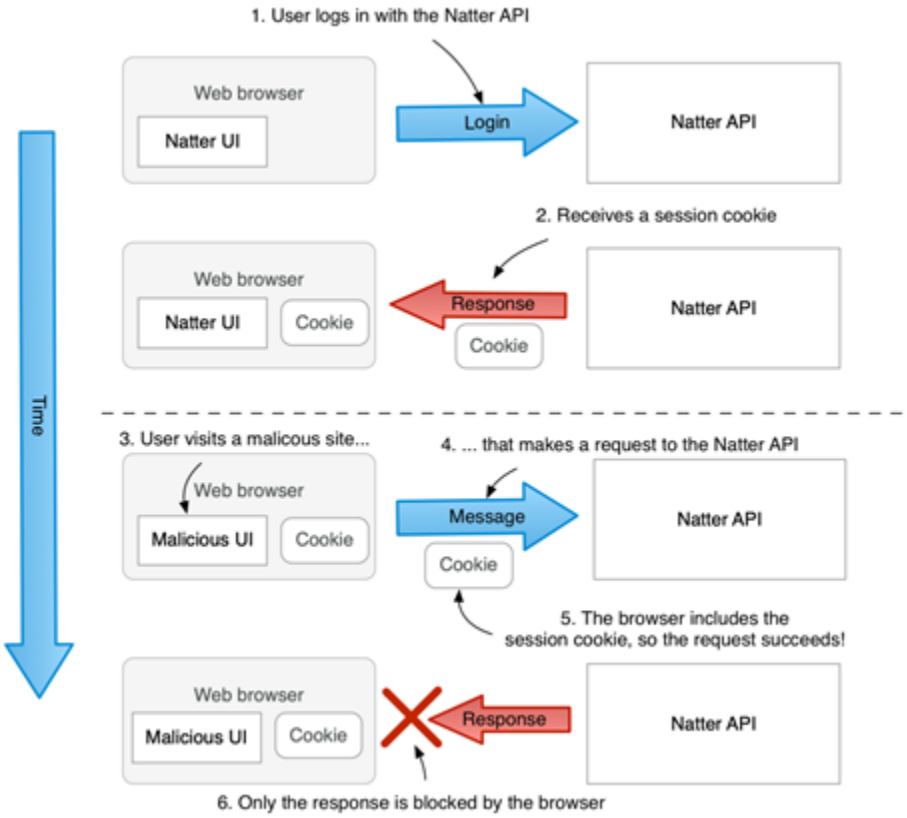


Figure 4.9 In a CSRF attack the user first visits the legitimate site and logs in to get a session cookie. Later, they visit a malicious site that makes cross-origin calls to the Natter API. The browser will send the requests and attach the cookies, just like for a genuine request. The malicious script is only blocked from reading the response to cross-origin requests, not stopped from making them.

For JSON APIs, requiring an `application/json` Content-Type header on all requests makes CSRF attacks harder to pull off, as does requiring another non-standard header like the